Lovable Hosting & Security Report

Prepared by Legalbuzz (tech@legalbuzz.co) | 13 October 2026 | Reference project: Legalbuzz CRM (visibility.buzzintel.co)

How Lovable stores and hosts a project, and the security layers in front of it. Findings were checked by inspecting the live CRM site and its Lovable project (DNS, IP ownership records, server responses, database settings) and against Lovable's own documentation. Read-only checks; nothing was changed.

Summary

- Lovable keeps three things for each project: **the code**, **the published website**, and (optionally) **the database**. Each is stored and served differently.
- Everything is hosted by Lovable itself. Visitor traffic to the site, the preview and the database all passes through **Cloudflare's network**, and every connection is encrypted.
- Cloudflare only protects the connection. The most important protection for the data is the database's access rules: all 39 CRM tables have them switched on.
- Gaps: two browser security headers are missing (Lovable default), and Lovable does not publish which data centres it uses.

Part 1 — Where everything is hosted

1. Where the project (the code) is stored

- Each project is a code repository (version history) held in Lovable's own system.
- Every edit, by the AI or by you, is saved as a numbered change, like a save point. The CRM's latest one is `4ff8a8c`, saved 12 Oct 2026.
- That is why you can see what changed between versions and roll back.
- Images and files you upload are kept with the project.
- Connecting GitHub is optional. If you do, Lovable copies the code there too, so you hold your own backup.

2. How the live site is built and stored

When you click **Publish**:

1. Lovable takes the latest saved version of the code and turns it into a finished website: a small page plus bundled script and style files.
2. That finished copy is stored on Lovable's hosting as a numbered release. Every response from the CRM carries a release tag (`x-deployment-id: psr2.9dad...`), showing each publish is kept as a separate release.
3. The live site serves that release until you publish again. Edits in the editor do not affect the live site until then.

3. Where it is served from

- **Lovable's own servers:**
  - `.lovable.app` addresses resolve to `185.41.148.1` and `185.41.148.2`, registered to **"Lovable Network Operations"**.
  - Custom domains point to `185.158.133.1`. The CRM (`visibility.buzzintel.co`) is set up this way.
- **Delivered through a global network:** every response comes back with `server: cloudflare` and a `cf-ray` ID, so Lovable's hosting is delivered through Cloudflare's network and visitors get the site from a nearby location.
- **Caching:**
  - The page itself (`/dashboard`) is set not to be cached (`no-cache`), so visitors always get the newest release.
  - Script and style files are stored for a year (`max-age=31536000, immutable`). Their file names change on every publish (e.g. `index-DX1cGz4b.js`), so new versions take over straight away.

- **Traffic:** Lovable's docs say hosting "scales with traffic automatically", so there are no server sizes or plans to manage.

4. Where the data is stored (only if Lovable Cloud is on)

- Each project gets its own separate Supabase backend: database, logins and file storage. The CRM's is `qzlpabfkhdaxdsoelpqa.supabase.co`.
- It is stored in the region picked when Cloud was switched on (Americas, Europe or Asia Pacific), and it **cannot be moved later**.
- It is separate from the website. Re-publishing the site does not touch the data.

5. What Lovable does not publish

- Which cloud company or data centre physically stores the code and published sites; its docs only say "Lovable hosts your app".
- The exact city of each region.
- For data residency (e.g. UK/EU-only data for law-firm clients), ask Lovable Support. Enterprise plans can request specific countries.

Hosting at a glance

What	Where it lives	Verified by
Project code and history	Lovable's own repository system	Project change history
Published website	Lovable's hosting, one stored copy per publish	Release tag on every response
Delivery to visitors	Lovable's IPs, through Cloudflare's network	IP ownership records + server: cloudflare
Database, logins, files	Separate Supabase backend per project, in the chosen region	CRM's Supabase project reference
Domain name	Stays with you at your registrar	DNS lookup

Part 2 — Security layers, and is it served through Cloudflare?

Yes. Every part of a Lovable project checked (live site, private preview and database) runs through Cloudflare's network, and every connection is encrypted. But Cloudflare only covers the connection; the most important protection for the data is the database's access rules, which were checked too.

Layer 1 — Network: Cloudflare (verified)

- All three parts answer with `server: cloudflare` and a Cloudflare request ID: the published CRM site, the private preview (`id-preview--....lovable.app`) and the Supabase database endpoint.
- Traffic passes through Cloudflare before it reaches Lovable or Supabase, which gives baseline protection against floods of traffic (DDoS) and hides the servers' real addresses.
- **Not visible from outside:** which extra Cloudflare protections (firewall rules, bot blocking, rate limits) Lovable turns on. These are set in Lovable's own Cloudflare account; you cannot see or change them, and Lovable's docs do not describe them.

Layer 2 — Encryption (HTTPS) (verified)

- Plain `http://` requests are redirected to `https://` with a 301.
- **HSTS is on** (`max-age=31536000; includeSubDomains`), so browsers refuse to load the site over an unencrypted connection for a year.
- Lovable issues and renews the SSL certificate automatically.
- Not confirmed: which authority issues the certificate (the public certificate log was down at the time of checking).

Layer 3 — Browser security headers

Header	CRM site	Effect
Strict-Transport-Security	**On**	Forces HTTPS
X-Content-Type-Options	**nosniff**	Stops file-type tricks
Referrer-Policy	**strict-origin-when-cross-origin**	Limits what is leaked to other sites
Content-Security-Policy	**Not set**	Would limit which scripts can run (helps against injected code)
X-Frame-Options / frame-ancestors	**Not set**	Would stop other sites embedding the CRM in a frame (clickjacking)

The last two are a gap in Lovable's default hosting, not something introduced by the project.

Layer 4 — Access control on the app

- **Preview:** locked. It needs a Lovable login and returned "401 unauthorised" without one.
- **Published CRM:** the site is public, but the dashboard sits behind its own login page. Who can sign up or log in is decided by the app's code and settings.
- **Database endpoint:** refuses any request without a key ("401 missing API key").

Layer 5 — Database rules (the most important layer, verified)

- The website ships with a public database key; that is normal for Lovable/Supabase apps. The real protection is **row-level security**: per-table rules that decide who can read or change each row.
- CRM database: **39 of 39 tables** have row-level security switched on, none missing; **90 access rules** are defined across them.
- **Still to check:** that each rule is actually strict, e.g. that one client's data cannot be read by another logged-in user. Cloudflare cannot protect against a loose rule.

Security at a glance

Layer	Who provides it	Status
DDoS / network	Cloudflare (via Lovable)	**In place** — settings not visible to you
HTTPS + HSTS	Lovable / Cloudflare	**In place**
Browser security headers	Lovable hosting	**Partial** — no CSP, no frame protection
Preview access	Lovable	**Login required**
Database rules	Your app's setup in Supabase	**On for all 39 tables** — strictness not yet reviewed

Recommended next step

- Review the 90 database rules for any that let one logged-in user see another client's data — the most useful security check for a multi-client CRM.
- Ask Lovable Support (a) which data centres/provider host the code and published sites, (b) the exact location of the chosen backend region, and (c) whether CSP and frame-protection headers can be added.